

Diseño de modelos de turno y esquema de cobertura

Divier Jácamo Álvarez

Cetav La Libertad

Rol: Analista SOC L1

Fecha Lunes 02/03/26

Modelo de turnos de monitoreo

1. Introducción

Las clínicas de salud mental gestionan información profundamente privada, abarcando historiales médicos, diagnósticos psiquiátricos y datos personales delicados. Este tipo de información es considerada de suma importancia bajo diversos marcos regulatorios globales, lo que eleva la necesidad de contar con controles de ciberseguridad robustos.

Los ataques dirigidos hacia el ámbito de la salud, sobre todo los ransomware y la exfiltración de datos, han mostrado un incremento notable en los últimos años. En este contexto, la instauración de un modelo efectivo de turnos para el SOC es esencial para garantizar la supervisión continua, la detección temprana y una respuesta coordinada ante incidentes.

2. Marco Teórico

La gestión de incidentes debe incluir preparación, detección, análisis, contención, erradicación y recuperación además, la norma ISO/IEC 27001 resalta la importancia del monitoreo constante y la adecuada gestión de eventos de seguridad como parte del Sistema de Gestión de Seguridad de la Información.

En entornos con recursos limitados, como las pequeñas y medianas empresas en el ámbito de la salud mental, una planificación estratégica de turnos facilita el balance entre la disponibilidad operativa y la

sostenibilidad del personal.

3. Propuesta de Modelo de Turnos

Modalidad Operativa Recomendada: 8x5 con Guardia On-Call

Dado que la mayoría de las clínicas llevan a cabo sus actividades principalmente durante horas laborales, se sugiere un modelo de cobertura ampliada que incluya una guardia rotativa fuera del horario habitual.

Horario Base

SOC L1: 08:00am – 5:00pm

SOC L2: 09:00am – 6:00pm

Se establece una hora diaria de superposición para facilitar la transferencia de conocimientos y la coordinación de incidentes.

Guardia Fuera de Horario

Horario: 6:00pm – 08:00pm

La guardia se rota semanalmente entre L1 y L2 durante este tiempo, donde sólo se atenderán incidentes clasificados como críticos, tales como:

Detección de ransomware.

Acceso no autorizado a historiales clínicos.

Compromiso del dominio o servidores críticos.

Fallas en dispositivos de seguridad perimetral.

El tiempo máximo recomendado de respuesta es de 15 a 30 minutos desde la notificación.

4. Distribución de Responsabilidades

Funciones del SOC L1 (YO)

Como analista de primer nivel, soy responsable de:

Supervisión continua del SIEM.

Análisis inicial y clasificación de alertas.

Revisión de registros críticos.

Documentación de incidentes.

Escalamiento estructurado al SOC L2.

Funciones del SOC L2 (Karen)

El analista de segundo nivel tiene responsabilidades que incluyen:

Investigación exhaustiva de incidentes.

Análisis forense digital.

Contención y eliminación de amenazas.

Ajuste de reglas de correlación en el SIEM.

Mejora continua de los playbooks y controles técnicos.

Se recomienda dedicar al menos dos horas semanales a actividades de mejora continua y revisión de políticas de seguridad.

5. Clasificación de Incidentes

Se sugiere la siguiente categorización:

Crítico: Eventos que ponen en riesgo la disponibilidad o confidencialidad de datos clínicos.

Alto: Actividades maliciosas contenidas o múltiples intentos fallidos de acceso.

Medio: Intentos de phishing bloqueados o actividad sospechosa aislada.

Bajo: Eventos informativos que no tienen un impacto directo.

Esta clasificación permite priorizar recursos y mitigar la fatiga operativa.

6. Procedimiento de Handoff Diario

Se establece un proceso formal de transferencia de turno de 15 minutos que debe incluir:

Incidentes activos.

Alertas que están pendientes de análisis.

Reglas que requieren ajustes.

Riesgos emergentes.

Recomendaciones operativas.

La documentación estructurada asegura la trazabilidad y el cumplimiento normativo.

7. Indicadores de Desempeño

Para evaluar la eficacia del modelo, se sugiere medir:

Tiempo Medio de Detección (MTTD).

Tiempo Medio de Respuesta (MTTR).

Tasa de falsos positivos.

Cantidad de incidentes críticos mensuales.

Alertas fuera de horario.

Estos indicadores facilitan la justificación de recursos ante la gerencia y optimizan la operación.

Discusión

El modelo 8x5 con guardia rotativa proporciona un equilibrio entre la sostenibilidad operativa y la cobertura estratégica en una PYME con recursos limitados la implementación de procesos formales de escalamiento y documentación disminuye el riesgo de omisiones críticas, sobre todo en entornos donde se prioriza la confidencialidad de la información.

Si la clínica opera las 24 horas, los 7 días de la semana, podría evaluarse un modelo de turnos 12x12 este enfoque puede causar una fatiga considerable en equipos pequeños y lo cual debería considerarse ser analizado con atención.

Conclusión

La adopción de un modelo estructurado de turnos en un SOC pequeño que protege una clínica de salud mental es una decisión estratégica clave para asegurar la continuidad operativa, el cumplimiento normativo y la protección de información sensible el esquema sugerido proporciona cobertura ampliada, escalamiento claro entre niveles y sostenibilidad del personal, reduciendo de manera significativa el riesgo institucional frente a amenazas cibernéticas.

Esquema de cobertura operativa

Introducción

Las clínicas de salud mental manejan información extremadamente delicada, que incluye registros médicos, diagnósticos psiquiátricos y datos personales confidenciales este tipo de información demanda medidas de seguridad estrictas debido a las consecuencias legales, de reputación y éticas que surgen en caso de su violación.

En este marco, el esquema de cobertura operativa del SOC debe asegurar que, sin importar la distribución del personal a lo largo del tiempo, haya una capacidad efectiva para la vigilancia, la respuesta y la contención frente a incidentes críticos la cobertura operativa es un elemento fundamental de la resiliencia organizacional y la continuidad del negocio.

2. Marco Normativo y Conceptual

El (NIST, 2012) indica que la gestión de incidentes debe abarcar preparación, detección y análisis, contención, erradicación y recuperación. Además, la norma ISO/IEC 27001 requiere la implementación de monitoreo continuo y la gestión de eventos de seguridad dentro del Sistema de Gestión de Seguridad de la Información.

Siguiendo estas directrices, la cobertura operativa no se restringe al monitoreo técnico, sino que también incluye procedimientos formales de activación, priorización y escalamiento.

3. Objetivos del Esquema de Cobertura Operativa

El esquema propuesto busca alcanzar los siguientes objetivos:

Asegurar una respuesta continua y rápida ante incidentes críticos.

Proteger la confidencialidad, integridad y disponibilidad de la información clínica.

Establecer plazos máximos para la detección y respuesta.

Definir criterios claros para el escalamiento en los diferentes niveles del SOC.

Garantizar la trazabilidad documental para cumplir con normativas y auditorías.

4. Niveles de Cobertura

Cobertura Operativa Activa

Durante el horario de trabajo, se realiza un monitoreo continuo del SIEM, revisión de eventos

críticos y análisis de las alertas generadas por:

Firewall perimetral.

Soluciones EDR.

Active Directory.

Servidores clínicos.

Accesos remotos.

Esta fase se enfoca en la detección temprana y la contención oportuna.

Cobertura Reactiva Fuera de Horario

Fuera del horario laboral, se activa la cobertura según un esquema de atención basado en la criticidad solo los incidentes categorizados como críticos provocan una activación inmediata.

Se consideran eventos críticos:

Ransomware en actividad.

Exfiltración de datos clínicos.

Acceso no autorizado a registros médicos.

Compromiso del dominio institucional.

Fallo de la infraestructura de seguridad perimetral.

El tiempo máximo de respuesta establecido es de 15 a 30 minutos desde la notificación.

5. Clasificación y Priorización de Incidentes

Se utiliza una matriz de criticidad que está organizada en cuatro niveles:

Nivel 1 – Crítico: Impacto directo en los datos clínicos o disponibilidad institucional.

Nivel 2 – Alto: Actividad maliciosa contenida con riesgo potencial de incremento.

Nivel 3 – Medio: Eventos sospechosos sin pruebas de compromiso activo.

Nivel 4 – Bajo: Eventos informativos o falsos positivos.

La priorización permite distribuir los recursos de manera efectiva y disminuir la carga

operativa.

6. Procedimiento de Escalamiento

El esquema establece una trayectoria formal para el escalamiento:

Detección y clasificación inicial.

Documentación en un sistema de tickets.

Notificación al nivel superior si el incidente excede las capacidades técnicas del nivel básico.

Activación del protocolo de respuesta a incidentes críticos cuando es necesario.

Informe ejecutivo a la dirección en caso de un impacto notable.

Este procedimiento asegura trazabilidad y cumplimiento de las normativas.

7. Plan de Contingencia

En caso de que falte personal clave o haya una indisponibilidad técnica, se consideran las

siguientes acciones:

Priorización exclusiva de los incidentes críticos.

Activación de soporte externo especializado

Registro detallado para análisis futuro.

Revisión post-incidente (post-mortem) para la mejora continua.

El plan de contingencia refuerza la resiliencia del SOC frente a situaciones desfavorables.

8. Indicadores de Desempeño

Para medir la eficacia del esquema de cobertura, se definen los siguientes indicadores:

Tiempo Medio de Detección (MTTD).

Tiempo Medio de Respuesta (MTTR).

Porcentaje de incidentes críticos solucionados dentro del SLA.

Cantidad de accesos no autorizados detectados fuera del horario.

Tasa de falsos positivos.

Estos indicadores permiten evaluar la eficiencia operativa y respaldar decisiones estratégicas ante la dirección institucional.

9. Discusión

En contextos con recursos limitados, la cobertura operativa debe ser configurada considerando criterios de priorización y automatización. La utilización de herramientas avanzadas de correlación y respuesta automatizada puede disminuir la carga de trabajo manual y aumentar la capacidad de respuesta frente a amenazas emergentes.

Además, la formación constante del personal refuerza la habilidad analítica y disminuye el riesgo de errores en la categorización de incidentes.

10. Conclusión

El esquema de cobertura operativa actúa como un componente estratégico para salvaguardar

una clínica de salud mental contra ciberamenazas. A diferencia del modelo de turnos, este enfoque se enfoca en mantener la continuidad del servicio de seguridad, la gestión ordenada de incidentes y el cumplimiento de las normativas su adecuada implementación incrementa la resiliencia institucional y protege la información clínica sensible, reduciendo riesgos legales y de reputación.

Referencias

Achraf Chamkar, S., Maleh, Y., & Gherabi, N. (2024). *Security Operations Centers: Use Case Best Practices, Coverage, and Gap Analysis Based on MITRE Adversarial Tactics, Techniques, and Common Knowledge*. *Journal of Cybersecurity and Privacy*, 4(4).
<https://doi.org/10.3390/jcp4040036>

Canadian Centre for Cyber Security. (s. f.). *Best practices for setting up a security operations centre (SOC)* (ITSAP.00.500). Retrieved March 2, 2026, from
<https://www.cyber.gc.ca/en/guidance/best-practices-setting-security-operations-centre-soc-itsap00500>

Tecnetone. (s. f.). *Implementar un SOC en tu Empresa: Guía Práctica Paso a Paso*. Retrieved March 2, 2026, from <https://blog.tecnetone.com/soc-ciberseguridad>

AlertMedia. (s. f.). *10 Security Operations Center Best Practices [+Risk Report]*. Retrieved March 2, 2026, from <https://www.alertmedia.com/blog/security-operations-center/>